

Cyber Security - Identity and IT Access Management Standard

1. Introduction

1.1 Background

The protection of Advanced Personnel Management (**APM**) Information Assets against unauthorised access via IT Assets is a basic business requirement, as well as a contractual and legal obligation which APM takes extremely seriously.

To achieve this protection, APM is committed to actively and effectively managing access to all APM IT Assets while providing users of APM IT Assets a secure and readily accessible IT environment in which to work.

1.2 Purpose

APM implements several layers of controls to preserve data confidentiality, integrity and availability. These controls can be either physical or logical (virtual).

APM's identity and IT access management controls are classed as logical and implemented across all APM IT Assets to provide authorised, granular and appropriate access to IT Assets. These controls, in conjunction with the standard of physical controls, as per *Physical IT Asset Security Standard*, help ensure preservation of data confidentiality, integrity and availability.

The intent of this document is to:

- communicate the need for system access control;

establish the minimum standards for controls required to protect against unauthorised access.

1.3 Scope

This standard applies to all Australian and New Zealand APM employees; contracted staff (permanent, temporary and casual) employed in APM's divisions and business units, and external suppliers (partners, sub-contractors / supply chain partners) and their staff, customers, clients.

This standard refers to Users as defined in the *Information Security Roles and Responsibilities Standard*.

2. Principles

APM has aligned its system access control approach to the principles outlined below:

Principle	Description
Efficiency	APM will provide all Users with the information they need to carry out their responsibilities / engage with the organisation in as effective and efficient a manner as possible
Responsive	All activities relating to this standard are carried out with the primary goal of ensuring APM will continue to conduct its business effectively and achieve its vision and purpose. System access control will be responsive to business needs wherever possible
Risk Aware	All activities relating to this standard are carried out to provide a balanced implementation of security commensurate to the assessed risk rating for APM IT assets
Role-Based Access Control (RBAC)	All access management is conducted using Role Based Access Control. Users are assigned access based on the roles relevant to their function in the organisation where appropriate authorisation is provided.
Least-Privilege and Need-to Know	Privileges are aligned to roles, and access to APM information is provided in accordance with the security principles of 'least privilege' and 'need - to-know'
Separation of Duties	No one person alone will be able to circumvent APM IT asset safeguards.

3. Access Management

The appropriate management of access will be achieved by the definition and adherence to clearly defined processes. These processes shall exist for each of the following major categories of access control:

1. Initial privilege provisioning;
2. Privilege escalation, de-escalation or modification;
3. Administrative privilege provisioning; and
4. Termination.

Access to APM IT Assets and information assets via these IT Assets, will be given through the provision of a unique APM user account and complex password via APM's directory service. No access to any APM IT Assets will be provided without prior authentication and authorisation of a user's APM user account

4. Identification and Access Management

APM controls the access to IT Assets by employing controls such as password management, multi-factor authentication and network access. These controls form part of the following identification and access activities:



4.1 User Identification and Authentication

Allocation of unique identifiers (ID) to all users for their sole and personal use allows activities to be subsequently traced to the responsible individual. A combination of technologies and mechanisms such as passwords, smart cards, biometrics, and memory tokens can be linked to provide strong authentication. These unique identifiers must comply with the following standards:

1. A user's identifiers shall not give any indication of the user's privilege level.
2. Shared user IDs for a group of users, or for a specific job, should be avoided unless there is a business justification which has been approved by the Cyber Security Team. However, with the exception of Break Glass emergencies (as per section 4.2.3 of this document) shared user IDs must not be used for accessing sensitive applications containing personal, client, financial or operational data.
3. User authentication information is stored in APM's Active Directory (AD) and Azure Entra ID Services and separate to the IT System Asset it grants access to.
4. To mitigate the risk of external users gaining unauthorised access to APM computers via public networks, all connections originating from public or other external networks must be authenticated using two factors.

4.1.1 Password Management

Account	Password Management
Users	• The use of individual passwords is enforced to maintain accountability. • Password length, complexity and expiration times will be controlled through APM's User access directory service. This must be configured as per section 4.3 System Configuration Management of this document. • When a user account is created, and when a user password needs to be changed, a randomly generated (not predictable) one-time password is to be issued. The user is to change this password at first logon. • Administrators are to positively authenticate a user's identity prior to complying with a request to change passwords. • Users are to be required to change their passwords immediately following a security incident involving their account or equipment. This includes but is not limited to: ○ Following a virus infection or successful phishing attack. ○ They are directly compromised. ○ They are suspected of being compromised. ○ They appear in an online data breach database. ○ They are discovered stored on networks in the clear. ○ They are discovered being transferred across networks in the clear. ○ Membership of a shared account changes ○ Credentials have not been changed in the past 12 months
IT Equipment	• Where supported, default equipment passwords are to be changed on all APM IT assets, including endpoint devices such as network devices or printers, prior to their being connected to any APM environment.
IT Systems	• Administrators are to have separate login credentials for accessing servers to the credentials used for everyday helpdesk administration tasks. • Administrative accounts must be identifiable as such. • Administrators and developers are to have separate login credentials for accessing the development environment to the credentials used for everyday helpdesk and administration tasks.

	- Administrative and development accounts must be identifiable as such. - APM systems and processes are not to permit the transmission of passwords in clear text over a network. - No APM systems are to store passwords (including in cache memory) in a manner whereby they may be uncovered and/or re-used.
SSH	- Authentication of accounts via SSH will occur via APM's user Active Directory Service or Entra ID. - SSH connections are only to be established from the management network. - The lockout policy applies to prevent brute force attempts at a SSH passphrase.

4.1.2 Multi-Factor Authentication

Multi-factor authentication is used to authenticate all Users.

Authentication methods susceptible to replay attacks are to be avoided.

External services should use Single Sign On (SSO) wherever possible.

When Systems cannot support multi-factor authentication, single-factor authentication is used requiring a minimum of 15 characters.

4.1.3 Physical Credentials

Physical authentication devices, including smart cards, tokens, and FIDO security keys, must be stored securely and kept separate from the systems they provide access to, except when actively used for authentication.

4.1.4 Separation of Duties

Separation of duties and responsibilities will be used to ensure no one person can circumvent normal auditing processes.

The minimum implementation will be to separate the roles of Systems Administrator and Application Manager for all systems holding confidential or financial information, or any system identified as a corporate system.

Operational responsibility for networks will be separated from responsibilities for computer operations where possible.

4.2 Account Management

4.2.1 Account Creation

Account creation will only occur when a person's identity has been formally verified, and they become a User by registering:

- As a current staff member, through APM Human Resources recruitment and onboarding processes; or
- Complete the Request for Access to APM IT Assets process and are registered as a Third-Party User; and

4.2.2 Account Requirements

Account Type	Requirements
Privileged	- Prior to making any changes, HR or the ITSA must approve any special rights. - A record shall be maintained of all special privileges granted. - These accounts must be restricted in their use.

Account Type	Requirements
	4. Passwords for Privileged accounts must be at least 15 characters in length. 5. Privileged accounts must not be used to read emails or access unauthorised web content. 6. Where practicable, special privileges shall only be allocated to individuals for the duration of the task that requires the privilege. The privilege shall then be promptly withdrawn. 7. The use of system utilities and devices capable of bypassing system access controls must be strictly limited and monitored. Usage of such tools must be logged and subject to review.
System Administrator	8. Default system administrator accounts have their passwords automatically changed every 30 days using Local Administrator Password Solution (LAPS). 9. Passwords for Local Administrator accounts including those managed by LAPS, must be at least 30 characters in length. 10. Distinct passwords are applied to each account. 11. Guest accounts are disabled. 12. Database administrators have unique and identifiable accounts and are not shared across different databases.
Standard User	13. To enable Role Base Access Control (RBAC), standard user access profiles shall be considered for common job categories
Generic	14. The use of shared, guest, anonymous and other such generic user accounts shall be avoided where possible. If guest or anonymous accounts must be used to access APM IT assets, they must be supported by a process that identifies the user of the account, such as a record of account allocation. 15. Wherever possible, generic accounts must have the minimum rights and privileges required to perform their role and must not be used to access any corporate IT systems or stores of confidential information. 16. Whenever membership of a shared account changes the password must be reset. 17. Generic accounts should have their password reset if they have not been changed in the past 12 months.
Service Accounts	18. Service accounts must be created as group Managed Service Accounts; Virtual Accounts; or Managed Identities where possible. 19. Passwords for interactive service accounts (user objects) should have a password of at least 30 characters. 20. Passwords for interactive service accounts (user objects) should be changed if: 21. They are directly compromised 22. They are suspected of being compromised 23. They appear in an online data breach database 24. They are discovered stored on networks in the clear 25. They are discovered being transferred across networks in the clear 26. An individual with access to the password leaves or moves to a role that does not require access 27. They have not been changed in the past 12 months 28. Service accounts should only be given the permissions required to perform their function. 29. All service accounts must be assigned an owner
Third Party	30. As well as the requirements documented in the <i>External Supplier Security Standard</i>, third parties, their supply chain partners and/or employees must:

Account Type	Requirements
	31. Be issued with unique user accounts, but under no circumstances are shared credentials to be permitted. 32. Notify the relevant APM Account manager if they identify any unauthorised access to APM Information Systems.

4.2.3 Break Glass (Emergency Access) Accounts

Emergency access accounts, often referred to as "break glass accounts" are highly privileged and must only be used when normal admin accounts cannot sign into a system and emergency access is required.

Examples of situations which constitute emergency access include but are not limited to:

1. Multi-factor authentication cannot be completed due to a network outage, causing failure with individual devices and local phone service. This outage can occur as a result of a catastrophic event such as a natural disaster.
2. A privileged account user is either unavailable or has left the company and the account is unrecoverable.

They must be controlled by an Emergency Account Manager who will:

- Be readily available during normal business operating hours.
- Understand the sensitivity and priority of the emergency accounts.
- Ensure that the requester has been positively identified before being granted emergency access.
- Record the access request for audit purposes.

If a business decision is made to implement a break glass account on a particular IT Software Asset, the break glass account must adhere to the following requirements:

Principle	Requirements
Essential use only	Emergency access via Break Glass Accounts is to be restricted to those times when access is essential, and normal administration accounts cannot log in.
Authorised access only	All emergency access to IT Systems via Break Glass Accounts must be approved by the Emergency Account Manager or nominated delegate.
Authorised Users	A list of authorised Admins who can use the break glass accounts must be maintained. These personnel must hold the Global Admin role under normal circumstances
Account Name	The account name must not identify the account as a break glass account.
Username	Must be complex and hard to guess
Password	Break Glass accounts should have a password of at least 30 characters.
Configuration	Should be configured so they are not impacted by an emergency where normal administration accounts cannot log in, e.g., MFA has become disabled.
Updating Credentials	Credentials must be changed by the Account Custodian after they are accessed by any other party
Authorised Activities	Break Glass Accounts must only be used for specific authorised activities.

Principle	Requirements
Audit Access	All activity on Break Glass Accounts must be logged and audited regularly for any unexpected activity. Access to any of these accounts must trigger immediate notifications to other administrators.
Validation and Testing	The Break Glass accounts must be checked, validated and the process tested regularly, including whenever credentials have been updated, or when there has been a change to fundamental IT infrastructure or to key personnel involved with this process.

4.2.4 Account Auditing

Periodic auditing of accounts will be performed by APM's D&T Department to identify and revoke non-active, unused or non-authorised accounts; or to perform the reallocation or revocation of privileges.

Privileged account access rights such as Domain Admin are reviewed on a regular basis by the D&T Operations Manager.

4.2.5 Account Deactivation

Upon termination of a User, the User's APM account will be deactivated across all IT Systems, on the same day the relationship ends. A User's account may also be deactivated in the following circumstances:

- suspected malicious activity; or
- more than 30 days of inactivity.

4.3 System Configuration Management

The following details APM's security requirements for system configuration management:

Control	Security Requirements
Least Privilege	Users, and the applications acting on their behalf, must only be granted the minimum required access to operating system functions to perform their duties
Access Notification	On activation of a device, or on connection, internally and externally to the APM Network by an individual, a general notice will be displayed to the person stating that the system should only be accessed by Authorised Users
Password Storage	Password Files must be encrypted and stored separately from main application system data
Password Configuration for standard user accounts (non-privileged or non-administration accounts)	1. Force users to change temporary passwords at first logon 2. Include confirmation procedures to allow for typing errors when creating or changing passwords 3. Enforce regular password changes at least every 90 days 4. Where systems provide facilities to prevent passwords being reused for a predefined period, the facility will be set to prevent users from reusing the previous 3 password iterations; (prevent the reuse of past passwords)

Control	Security Requirements
	5. Prevent passwords from being displayed on screens in clear text when being entered 6. Prevent users from changing passwords more than once per day 7. Passwords must meet the following minimum requirements when they are changed or created: a. MUST be a minimum of 8 characters. b. MUST NOT contain significant portions of the User's account name or full name; c. MUST contain characters from three of the following four categories: i. English uppercase characters (A through Z); ii. English lowercase characters (a through z); iii. Base 10 digits (0 through 9); iv. Non-alphabetic characters (for example, !, \$, #, %).
User Account Locks	• User accounts must be automatically locked after five (5) failed logon attempts. • The account is only to be unlocked after the system administrator has proven the identity of the account User as the authorised User of that account.
Session/Screen Locks	Session or screen locks will be enabled on all APM Staff computers and systems which: • activates either after a maximum of 15 minutes of user inactivity or if manually activated by the user (CTRL+ALT+DEL); • completely conceals all information on the screen; • ensures that the screen does not enter a power saving state before the screen or session lock is activated; • requires the user to reauthenticate to unlock the system; • denies users the ability to disable the session or screen locking mechanism.
Segregation of Critical Online Services	Critical online services are segregated from other online services that are more likely to be targeted. APM's network is segregated from all other online services. Only the minimum and necessary data needed to be shared with any outside party is given. This ensures control over APM data and assets and reduces APM's attack surface and risk.
IMPORTANT – ANY IT APPLICATION OR OTHER IT SOFTWARE ASSET WHICH CAN NOT BE CONFIGURED TO THESE REQUIREMENTS MUST BE RISK ASSESSED AND AN EXEMPTION SOUGHT FROM THE CYBER SECURITY TEAM	

4.4 Application Management

- Standard users do not have the ability to uninstall or disable APM-approved software.
- Unauthorised access to the authoritative source for software is prevented.
- Cryptographic hash rules, publisher certificate rules and path rules used for application control are validated annually.

4.5 Access Management Reviews

Regular reviews are conducted to ensure that access to APM IT Assets is managed systematically and comprehensively. Such reviews will check for correct approvals and that processes have been correctly implemented. Reviews will also check that transfers and terminations have been completed correctly. Where a non-compliance is identified or suspected, an Information Security Incident / Breach will be raised using an Incident Reporting System.

5. Clients Access Management

To meet contractual obligations, APM provides clients access to IT Assets, including equipment, systems, and internet. For example, job seekers may require access to a computer to apply for jobs.

Client systems are used by users who are not authorised to access APM IT systems, therefore must not be connected to any other APM IT systems.

APM employees shall NOT utilise IT Assets designated for client use to perform their APM duties.

These clients are not included in APM's definition of a User, so access to the provided APM IT Assets must conform to the following standards:

- 1) APM IT Assets used by clients must not be connected to any non-public APM IT Systems.
- 2) Any IT Asset used by these clients must be developed and maintained following process and work instructions specific to these Assets, which will incorporate APM security principles.
- 3) When using these systems, personal information of the client may be temporarily stored. APM will not retain or utilise any of this information. To prevent the personal information being misused APM will ensure that these process and work instructions will ensure that no information created by the client is stored on the IT Asset.
- 4) Clients will be provided guidelines for the acceptable use of APM IT Assets to ensure they are aware of all their responsibilities while using the systems.

6. Compliance

Non-compliance with this Standard may lead to disciplinary action being pursued in accordance with APM's Code of Practice.

7. Related Legislation or Documents

- *Physical IT Asset Security Standard*
- *Information Security Roles and Responsibilities Standard*
- *APM Information Security Code of Practice*

8. Approval and Implementation

Content Owner:	Chief Information Security Officer
Content Expert:	Enterprise Technology Manager; Information Technology Security Advisor
Approval Date:	15/12/2022
Effective From:	10/07/2024

9. Review

Update this document whenever requirements change and review at least every year.

10. Definitions

Term	Definition / Explanation / Details
Brute Force attempt	An unsophisticated and exhaustive process to try and determine a cryptographic key or password without the user's knowledge by systematically trying all alternatives or combinations until the correct one is discovered.
Cache Memory	Cache memory is a small temporary storage area of computer memory that provides high-speed data access to a processor and stores frequently used computer programs, applications and data
Constrained RBAC Model	The constrained Role Based Access Control (RBAC) model adds 'separation of duties' to the standard RBAC requirements.
Cryptographic Hash Rules	The rules which apply to cryptographic algorithm (the hash function)
Default Equipment Password	Where a device needs a username and/or password to log in, a default password is usually provided that allows the device to be accessed during its initial setup, or after resetting it to factory defaults.
HR	Human Resources
IT Systems	A related set of IT Equipment Assets and IT Software Assets collectively used for the processing, storage or communication of information and the governance framework in which it operates.
IT Assets	Collective term for IT Equipment Assets (physical IT devices) and IT Software Assets (applications, software).
IT Software Asset	The IT software used to process, store or disseminate information assets. This will include both purchased software and freeware and any cloud service (Software as a System as an example).
ITSA	Information Technology Security Advisor
Least Privilege Principle	Users, and the applications acting on their behalf, must only be granted the minimum required access to operating system functions to perform their duties
Lockout Policy	Session or screen locks which activate after a set time to conceal all information on IT device screens, and require the user to reauthenticate to unlock the device
Managed Service Accounts	Managed domain accounts that provides automatic password management, simplified service principal name (SPN) management and the ability to delegate the management to other administrators.
Mission critical	Vital to the functioning of an organisation
Multi-Factor Authentication (MFA)	A method of computer access control in which a user is granted access only after successfully presenting several separate pieces of evidence to an authentication mechanism – typically at

Term	Definition / Explanation / Details
	least two of the following categories: knowledge (something they know), possession (something they have), and inherence (something they are).
Need-to-Know Principle	The principle of restricting an individual's access to only the information they require to fulfil the duties of their role.
NIST	National Institute of Standards and Technology
Passphrase	A sequence of words used for authentication.
Password	A sequence of characters used for authentication.
Path Rules	A rule applied to an application identified by its location in the file system of the computer or on the network.
Privileges	The rights provided to a unique user on a system in order to complete their role in the organisation.
Protected Users Security Group	A named security group within Active Directory.
Publisher Certificate Rules	Advanced rules that allow files digitally signed by the Certificate Publisher. These should combine both the publisher name and the product name.
Replay Attack	An attack that involves the capture of transmitted authentication or access control information and its subsequent retransmission with the intent of producing an unauthorized effect or gaining unauthorized access.
Role Based Access Control (RBAC)	Access control based on user roles (i.e., a collection of access authorizations a user receives based on an explicit or implicit assumption of a given role). Role permissions may be inherited through a role hierarchy and typically reflect the permissions needed to perform defined functions within an organization. A given role may apply to a single individual or to several individuals.
SSH	Secure Shell. A network protocol that can be used to securely log into, execute commands on, and transfer files between remote workstations and servers.
Third Party User	Any supplier, service provider, consultant, contractor etc working with or for APM who is not a permanent employee of APM, and has been authorised to access APM IT systems
Virus	A type of malware. Viruses spread on their own by attaching code to other programs or copying themselves across systems and networks.

11. Version Control

Version	Date	Prepared by	Comments
0.1	04/02/22	IS Policy Remediation Project Team	Supersedes the following documents:

Version	Date	Prepared by	Comments
			○ Information Technology – System Access Control Policy. ○ Sub-Contractor Supply Chain System Access Control ○ Third Party Access Policy • New template for “Standards” used”. • Document uplifted as per IS Policy Remediation Project – refer to documentation for overview of changes. • Removed detailed processes in relation to that belong in process documents: • Account Creation & Activation • Account Deactivation • Emails: Employee Departing • Emails: Employee Absences • Emails: Investigations • Identification
0.2	03/02/02	IT Change Manager	Corrected "user access directory service" to "Active Directory Service".
0.3	09/03/22	IS Policy Remediation Project Team	• Minor punctuation, grammatical and spelling corrections throughout. • Minor sentence restructure in some areas to improve readability – no content change • Swapped order of bullet points around to improve flow and readability in section 4.2.2 • Updated Glossary definition for IT Assets and Information Systems
0.4	03/06/22	IS Policy Remediation Project Team Regional Manager Security Assurance and Advisory	• Removed reference to APM operating a “Constrained RBAC model according to NIST Guidelines”. • Under section 4.1, point 2, clarified break glass emergencies were the exception to using shared ID’s when accessing sensitive applications. • Under section 4.1, removed reference to an “access control list” being in place through a secure gateway, as this is not currently implemented. • Under section 4.1.1 ○ Updated table heading to “Password Management”. ○ Added reference to section 4.3 System Configuration Management under point 2 of Password Management for Users. ○ Added “successful phishing attack” as another particular reason for changing a password.

Version	Date	Prepared by	Comments
			○ Provided “network devices or printers” as examples of endpoint devices under IT Equipment. ○ Added requirement for SSH connections to only be established from the management network. • Under section 4.1.2 removed “multi-factor authentication is used to authenticate all Users when accessing important data repositories” as redundant description. • Under section 4.1.3 replaced “must” with “will” in line beginning “operational responsibility”. • Under section 4.2.1 removed the reading and signing of the APM <i>Information Security Code of Practice</i> as a pre-requisite of account creation as this occurs after account creation. • Under section 4.2.2: ○ removed requirement for privileged account types to have dedicated workstations as currently not implemented. ○ Removed specification for all privileged accounts to be members of the Protected User security group. ○ Clarified for generic account types, service accounts must be created as Managed Service Accounts “where possible”. ○ Removed dot points from third party account sections which were duplicated in the <i>External Supplier Security Standard</i>. • Added section 4.2.3 “Break Glass (Emergency Access) Accounts. • Added to section 4.2.5 account deactivation will occur across all IT Systems. • Under Section 4.3 and the control for Password Configuration, clarified this is for “standard user-accounts (non-privileged or non administration accounts). • Added to section 4.3 a requirement for any IT Applications or other IT Software which cannot be configured to any of the security requirements must be risk assessed, and an exemption sought from the IT Security Team. • Under section 5, removed reference to “JobSeeker SOE Build Checklist” as other instances now exist, e.g. RACA.

Version	Date	Prepared by	Comments
			Removed reference to "JobSeeker SOE Build Checklist" from section 7.
1.0	14/12/2022	Information Security Officer	- Updated section 8 content expert role title. - Under section 4.1.1, updated criteria under which a password reset is required.
2.1	05/05/23	IT Operations Manager	Reviewed
2.2	19/06/2023	Information Security Officer	Updated Section 1.2, Physical IT Asset Security Standard name. Updated section 4.1, item 3 to include Azure AD. Updated section 4.1.1 "IT Equipment" to include "Where supported". Removed service account requirements from Generic accounts row in 4.2.2. Added Service accounts row to 4.2.2 including requirements. Updated section 4.2.4, removed trailing space. Fixed numbering in section 4.3, Password configuration row. Updated section 7, Physical IT Asset Security Standard name.
2.3	10/08/2023	Information Security Officer	Updated section 4.2.3 to specify minimum password length of 30 characters.
4.0	01/07/2024	Head of Cyber Security – APAC	Standard renamed to "Cyber Security" Minor spelling, grammar and formatting changes Section 4.1 - updated cyber security team name - Updated AAD to Entra Section 4.1.1 - updated requirement to change default equipment passwords from "production environment" to "any APM environment" - updated SSH authentication directories to include Entra Section 4.2.2 - updated privileged web access to "authorised" - updated bullet point numbers Section 4.2.3 - updated wording for password requirement Section 4.2.4 - updated D&T team name Section 6 - update code of practice name

Version	Date	Prepared by	Comments
4.1	12/11/2024	Enterprise Technology Manager	Updated User Password Management conditions for requiring credential changes.
4.2	23/12/2024	Enterprise Technology Manager	Updated Multi-Factor Authentication to recommend the use of SSO in external systems
4.3	01/07/2025	Head of Cyber Security – APAC	Section 4.2.2 • Updated Numbering • Added minimum password length for privileged accounts • Added minimum password length for system administrators
4.4	15/12/2025	IT Accreditation Manager	• Updated section 4.1.2 Multi-Factor Authentication to include reference to single-factor authentication ISM-0417 • Added section 4.1.3 for physical credentials